



Université du Québec
à Chicoutimi

Module d'informatique et de mathématique
Département d'informatique et de mathématiques

Rapport

Travail pratique #2

OUTIL DE DECOUVERTE DE VULNERABILITE ET EVALUATION D'UNE
CHAINE DE VULNERABILITE

Cybersécurité défensive : vulnérabilités et incidents

8SEC201

Groupe 01

Hiver 2025

REALISE PAR :

Mamadou Talibe DIALLO

Abdoulaye LOUBARASSEM

1. Introduction

Dans le cadre de ce travail pratique, un scan de vulnérabilités a été réalisé à l'aide de l'outil **Nessus** afin d'identifier les failles de sécurité présentes sur plusieurs machines. Cette analyse permet de mieux comprendre les risques associés aux systèmes informatiques et l'importance de leur sécurisation.

L'objectif de ce TP est de sélectionner deux vulnérabilités, de construire une chaîne de vulnérabilités et d'évaluer leur impact à l'aide du score CVSS. Les mesures de correction seront également étudiées à partir de la National Vulnerability Database (NVD), afin de proposer des solutions adaptées.

Enfin, des recommandations seront formulées concernant la gestion des correctifs, dans le but d'améliorer la sécurité des systèmes analysés.

2. Méthodologie et configuration

Pour réaliser ce travail, **Nessus** a été installé sur une machine virtuelle. Une fois installé, l'outil est accessible via une interface web en local.

Un scan de type "Basic Network Scan" a été configuré en utilisant les adresses IP fournies. Ce type de scan permet d'analyser les machines et de détecter les vulnérabilités présentes sur les systèmes.

Après le lancement du scan, les résultats ont été consultés et deux vulnérabilités ont été sélectionnées pour la suite du travail.

3. Résultats du scan

Le scan a permis d'identifier plusieurs vulnérabilités sur les machines analysées. Celles-ci sont classées selon différents niveaux de criticité, notamment critique, élevé, moyen et faible.

Cependant, la majorité des résultats sont de type informatif (Info), correspondant principalement à des informations sur les services détectés et la configuration des systèmes.

Malgré cela, certaines vulnérabilités de niveau plus élevé représentent un risque réel et peuvent être exploitées dans un contexte d'attaque.

4. Sélection des vulnérabilités

Parmi les vulnérabilités identifiées lors du scan, deux ont été sélectionnées pour l'analyse :

- **CVE-2016-2118** (Samba Badlock)
- **CVE-2016-2183** (SWEET32)

Vulnérabilité A : CVE-2016-2118 (Samba Badlock)

Cette vulnérabilité concerne le service **Samba** utilisé sur les systèmes Linux et Unix, et est connue sous le nom de **Badlock**.

Elle est liée à une mauvaise gestion de l'authentification dans les protocoles SAM et LSAD via les canaux RPC. Elle permet à un attaquant de type man-in-the-middle (MITM), capable d'intercepter le trafic entre un client et un serveur Samba, de forcer une dégradation du niveau d'authentification et d'exécuter des requêtes réseau dans le contexte d'un utilisateur légitime, pouvant ainsi accéder à des informations sensibles ou modifier des données.

- **Score CVSS v3 : 7.5**
- **Vecteur CVSS : CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:H/A:H**

Key Details :

- **Access Vector (AV) :** Networks (Exploitable à distance)
- **Attack Complexity (AC) :** High (Exige beaucoup d'effort pour effectuer une attaque)
- **Privileges Required (PR) :** None (Peuvent être exploités sans références)
- **User Interaction (UI) :** Required (Besoin d'utilisateur pour effectuer une action)
- **Confidentiality/ Integrity/Availability Impact (C I/A) :** High impact

Vulnérabilité B : CVE-2016-2183 (SWEET32 – SSL Medium Strength Cipher Suites)

Cette vulnérabilité concerne l'utilisation de suites de chiffrement SSL de force moyenne, notamment celles utilisant des clés de moins de 112 bits ou des algorithmes comme Triple DES.

Elle permet potentiellement à un attaquant situé sur le même réseau d'exploiter ces faiblesses cryptographiques pour tenter de récupérer des informations sensibles.

- **Score CVSS v3 : 7.5**
- **Vecteur CVSS : CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N**

Key Details :

- **Access Vector (AV) :** Networks (Exploitable à distance)
- **Attack Complexity (AC) :** Low (Exige peu d'effort pour effectuer une attaque)
- **Privileges Required (PR) :** None (Peuvent être exploités sans références)
- **User Interaction (UI) :** None (Pas besoin d'utilisateur pour effectuer une action)
- **Confidentiality Impact (C):** High impact
- **Integrity/Availability (I/A):** None

5. Chaîne de vulnérabilités (A -> B)

Cette section présente une chaîne de vulnérabilités composée de CVE-2016-2118 (Badlock) et CVE-2016-2183 (SWEET32), ainsi que son exploitation combinée. Elle décrit le scénario d'attaque et l'évaluation de son niveau de criticité à travers le calcul du score CVSS associé.

a- Attack Flow

- **Exploiter la vulnérabilité A (Samba Badlock) :** L'attaquant, sans identifiants, exploite la vulnérabilité à distance sur un service Samba vulnérable.

Grâce à cette faille, il peut :

- intercepter ou manipuler les échanges d'authentification SMB
 - se positionner comme un attaquant de type **man-in-the-middle (MITM)**
 - accéder à des sessions ou flux réseau initialement protégés
- **Exploiter la vulnérabilité B (SWEET32) :** Une fois le trafic accessible ou intercepté, l'attaquant exploite la faiblesse cryptographique liée aux chiffrements 64-bit (SWEET32).

Cela lui permet de :

- analyser des communications chiffrées affaiblies
- récupérer potentiellement des informations sensibles circulant dans les communications chiffrées
- compromettre la confidentialité des échanges après accumulation de données chiffrées

b- Construction du vecteur de chaîne

- **L'exploitabilité provient de B (SWEET32) :** comme B est plus facile à exploiter (à distance, aucun privilège requis, pas d'utilisateur requis), la chaîne hérite des indicateurs d'exploitabilité de B.
- **L'impact provient de A (Samba Badlock) :** comme A, a un impact beaucoup plus important, la chaîne hérite des indicateurs d'impact de A.

Vecteur final de la chaîne : CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

6. Évaluation du score de la chaîne de vulnérabilités

Vecteur de la chaîne : CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Paramètres CVSS :

Attack Vector (AV) = Network (0.85)

Attack Complexity (AC) = Low (0.77)

Privileges Required (PR) = None (0.85)

User Interaction (UI) = None (0.85)

Scope (S) = Unchanged

Confidentiality (C) = High (0.56)

Integrity (I) = High (0.56)

Availability (A) = High (0.56)

a. Calcul de l'impact :

$$ISS = 1 - [(1 - C) * (1 - I) * (1 - A)]$$

$$ISS = 1 - [(1 - 0.56) * (1 - 0.56) * (1 - 0.56)]$$

$$ISS = 1 - (0.44 * 0.44 * 0.44) = 0.91$$

$$\mathbf{ISS = 0.91}$$

$$\text{Impact} = 6.42 * ISS$$

$$\text{Impact} = 6.42 * 0.91 = 5.84$$

$$\mathbf{\text{Impact} = 5.84}$$

b. Calcul de l'Exploitability :

$$\text{Exploitability} = 8.22 * AV * AC * PR * UI$$

$$\text{Exploitability} = 8.22 * 0.85 * 0.77 * 0.85 * 0.85 = 3.88$$

$$\mathbf{\text{Exploitability} = 3.88}$$

c. Calcul du Base Score :

Comme le Scope = Unchanged, alors :

$$\text{Base Score} = \min((\text{Impact} + \text{Exploitability}), 10)$$

$$\text{Base Score} = \min((5.84 + 3.88), 10) = \min(9.72, 10) = 9.72$$

$$\mathbf{\text{Base Score} = 9.72 \text{ (Critical)}}$$

Le calcul du score CVSS de la chaîne de vulnérabilités donne un résultat de **9.72**, correspondant à un niveau critique. Ce score élevé s'explique par la combinaison d'une exploitabilité élevée, liée à une attaque possible à distance sans authentification, et d'un impact important sur la sécurité du système.

7 – Documentation des mesures de correction (Remédiation)

Vulnérabilité A : CVE-2016-2118 (Samba Badlock)

a- Solution :

Des correctifs ont été publiés pour les versions vulnérables de Samba afin de corriger les failles liées aux protocoles DCERPC (SAMR, LSARPC, LSAD).

Les versions corrigées incluent notamment :

- Samba 4.2.11 et versions ultérieures
- Samba 4.3.8 et versions ultérieures
- Samba 4.4.2 et versions ultérieures

Il est recommandé de :

- Mettre à jour Samba vers une version corrigée
- Appliquer les mises à jour de sécurité fournies par les distributions Linux
- Désactiver ou restreindre les services RPC/DCERPC non nécessaires
- Activer la signature et l'intégrité des communications SMB/DCERPC
- Limiter l'accès réseau aux services SMB (port TCP 445) via des règles de pare-feu
- Éviter l'utilisation de protocoles ou configurations permettant des niveaux d'authentification faibles (CONNECT)

b- Solutions de contournement :

Les mesures suivantes permettent de réduire le risque en attendant une mise à jour :

- Restreindre l'accès aux services SMB/DCERPC aux machines de confiance uniquement
- Filtrer les connexions RPC non essentielles au niveau du pare-feu
- Segmenter le réseau pour limiter les attaques de type man-in-the-middle
- Éviter l'utilisation de comptes privilégiés sur des réseaux non sécurisés
- Forcer l'utilisation de mécanismes d'authentification protégés (signature, intégrité, confidentialité)
- Désactiver les interfaces ou services DCERPC non nécessaires lorsque cela est possible

Vulnérabilité B : CVE-2016-2183 (SWEET32)

a- Solution :

Cette vulnérabilité est liée à l'utilisation de chiffrements reposant sur des blocs de 64 bits (notamment 3DES) dans TLS/SSL.

Les mesures correctives recommandées sont :

- Désactiver les suites de chiffrement utilisant des algorithmes à bloc 64 bits (ex : 3DES)
- Forcer l'utilisation de TLS 1.2 ou versions supérieures
- Mettre à jour les bibliothèques cryptographiques (ex : OpenSSL) vers des versions corrigées

- Configurer les serveurs pour utiliser uniquement des algorithmes robustes (AES, ChaCha20)
- Appliquer les recommandations du fournisseur concernant la configuration des suites cryptographiques

La vulnérabilité a été atténuée dans OpenSSL en déplaçant les suites DES du groupe HIGH vers MEDIUM.

Cependant, certaines implémentations (ex : Junos OS) continuaient à inclure ces suites via la configuration SSLCipherSuite.

Des versions corrigées de Junos OS ont ensuite supprimé le support du groupe MEDIUM, éliminant ainsi l'exposition à SWEET32.

b- Solutions de contournement :

Les mesures suivantes peuvent être appliquées :

- Désactiver explicitement les chiffrements faibles dans la configuration TLS/SSL
- Interdire l'utilisation des suites de chiffrement 3DES
- Limiter les sessions TLS afin de réduire l'exploitation statistique
- Vérifier régulièrement la configuration des services via des outils de scan de sécurité
- Mettre en place des politiques de sécurité imposant des suites cryptographiques modernes
- Surveiller et durcir les configurations des équipements réseau et systèmes exposés

8. Recommandations pour la correction de la chaîne de vulnérabilités

8.1 Approche générale

La chaîne de vulnérabilités formée à partir des vulnérabilités identifiées sur la machine 192.168.20.3, combinant CVE-2016-2118 (Badlock) et CVE-2016-2183 (SWEET32), présente un niveau de criticité élevé (CVSS 9.72).

Elle repose sur :

- une compromission initiale via une attaque de type man-in-the-middle (MITM)
- suivie d'une exploitation de faiblesses cryptographiques

Ainsi, la stratégie de remédiation doit s'appuyer sur une approche de défense en profondeur, visant à :

- éliminer les vulnérabilités à la source
- réduire la surface d'attaque
- limiter l'impact en cas d'exploitation

8.2 Correction de la vulnérabilité A : Samba Badlock

La vulnérabilité Badlock constitue le point d'entrée principal de la chaîne d'attaque. Sa correction est prioritaire afin d'empêcher toute compromission initiale du service SMB.

Mesures recommandées :

a. Application des correctifs

- Mettre à jour tous les services Samba vers une version corrigée
- Vérifier que le service SMB exposé sur la machine est à jour et correctement sécurisé

b. Renforcement des mécanismes d'authentification

- Activer la signature SMB (SMB signing)
- Désactiver les versions obsolètes du protocole (SMBv1)
- Forcer l'utilisation de protocoles d'authentification sécurisés (NTLMv2, ...)

c. Réduction du risque MITM

- Segmenter le réseau pour limiter l'exposition des services SMB
- Restreindre les ports 139 et 445 aux seuls flux nécessaires
- Utiliser des canaux chiffrés (VPN, tunnels sécurisés)

d. Tests et validation

- Tester les correctifs dans un environnement de préproduction
- Mettre en place un plan de retour arrière (rollback) en cas de dysfonctionnement

8.3 Correction de la vulnérabilité B : SWEET32

La vulnérabilité SWEET32 exploite des suites de chiffrement faibles utilisées dans les communications sécurisées. Elle permet d'intercepter et potentiellement d'exploiter des données chiffrées. Sa correction vise à garantir la robustesse des échanges.

Mesures recommandées :

a. Désactivation des algorithmes faibles

- Supprimer les suites de chiffrement basées sur Triple DES (3DES)
- Éliminer les clés de chiffrement inférieures à 112 bits

b. Mise à niveau des protocoles de sécurité

- Forcer l'utilisation de TLS 1.2 ou TLS 1.3
- Privilégier des algorithmes robustes tels que AES-GCM et ChaCha20

c. Vérification de la configuration

- Auditer les configurations SSL/TLS des services (serveurs web, services de messagerie, VPN)
- Utiliser des outils de scan pour valider la suppression des suites vulnérables

8.4 Stratégie de mitigation de la chaîne de vulnérabilités

La sécurisation ne doit pas se limiter à la correction individuelle des vulnérabilités, mais viser à rompre la chaîne d'exploitation.

a. Priorisation des actions

1. Correction de la vulnérabilité A (point d'entrée)
2. Correction de la vulnérabilité B (exploitation secondaire)

La suppression de l'une ou l'autre de ces vulnérabilités permet de rompre la chaîne d'attaque.

b. Mise en place de contrôles compensatoires

En cas d'impossibilité de correction immédiate :

- Mise en œuvre de la segmentation réseau
- Déploiement de systèmes de détection/prévention (IDS/IPS)
- Surveillance des flux réseau SMB
- Application du principe du moindre privilège

c. Automatisation du patch management

Afin de réduire les délais de correction :

- Automatiser le déploiement des correctifs sur la machine
- Planifier des cycles de mise à jour réguliers
- Réduire les interventions manuelles (sources d'erreurs)

d. Surveillance et amélioration continue

- Effectuer des scans de vulnérabilités réguliers
- Vérifier l'application effective des correctifs
- Maintenir un inventaire des actifs à jour

8.5 Gestion du risque résiduel

Même après remédiation, un risque résiduel peut subsister.

Il est recommandé de :

- documenter les vulnérabilités non corrigées
- évaluer leur impact potentiel sur la machine
- décider de leur acceptation, mitigation ou transfert

8.6 Conclusion

La correction de la chaîne de vulnérabilités observée sur la machine 192.168.20.3 repose sur une approche globale combinant :

- l'application des correctifs critiques
- le durcissement des configurations réseau et cryptographiques
- la mise en place de mécanismes de surveillance et d'automatisation

Cette démarche permet de réduire significativement la surface d'attaque et de limiter les risques de compromission des systèmes et des données.